12.4.1. 개인정보 보호 및 보안

제 정 일	2014.10.	최 종 개 정 일	2025.03.25.	최 종 검 토 일	2025.03.25.
담 당 부 서	정보보안팀				
유 관 부 서					

관 련 기 준	4주기 의료기관인증기준: 12.4 개인정보보호 및 보안 JCI Standard 7th Edition: MOI.2, 2.1, 12

제1조 (목적)

1. 진료과정에서 얻어진 다양한 개인정보를 안전하게 보호하기 위해 체계를 수립하고, 안정적으로 운영하기 위함이다.

제2조 (정의)

1. 개인정보: 살아있는 개인에 관한 정보로써 성명, 주민등록번호 및 기타 정보 등을 통하여 개인을 알아볼 수 있는 정보(해당 정보만으로는 특정 개인을 알아볼 수 없어도 다른 정보와 쉽게 결합하여 알아볼 수 있는 경우에는 그 정보를 포함한다.)
2. 제한구역: 비밀 또는 주요시설에 대한 비인가자의 접근을 방지하기 위하여 출입을 제한하는 구역
3. 통제구역: 비인가자의 출입이 금지되는 보안상 극히 중요한 구역

제3조 (절차)

1. 개인정보 보호 및 보안 관리는 개인정보보호법, 개인정보의 안전성 확보조치 기준, 연세의료원 개인정보 처리 방침에 따른다.

2. 개인정보 취급 관리 및 책임
   1) 개인정보보호 책임자는 관련법을 준수한다.
   2) 최고정보보호 책임자: 디지털헬스실장 – 연세의료원의 정보보호 업무 총괄
   3) 정보보호 책임자: 정보보안센터소장
   4) 정보보호 실무책임자: 정보보호 주관부서장
   5) 정보보호 관리자: 각 부서장 – 각 부서별 정보보호 업무 총괄
   6) 개인정보 보호 실무담당자
      (1) 의료정보시스템에 대해 이해하고 있는 자 또는 국내외 공인 정보 보호 유관 자격증을 보유한 자로 한해 지정한다.
      (2) 개인정보 보호 및 보안 관련 전문 교육(전문기관 교육, 보안세미나 등)을 이수한다.
      (3) 개인정보 보호를 위한 각종 활동계획 수립, 개인정보 보호 관련 정책 및 규정 수립의 지원, 개인정보 보호 관련 교육 및 훈련, 관련 법령 및 규범 등에 대한 문서화 및 유지관리, 환자의 개인정보 보호 관련 불만 및 고충처리 등의 업무를 수행한다.
   7) 보안 실무담당자

(1) 의료정보시스템에 대해 이해하고 있는 자 또는 국내외 공인 정보 보호 유관 자격증을 보유한 자로 한해 지정한다.
(2) 개인정보 보호 및 보안 관련 전문 교육(전문기관 교육, 보안세미나 등)을 이수한다.
(3) 외부로부터의 침입, 접근 및 해킹 등으로부터 개인정보시스템을 보호하여 개인정보가 유출되지 않도록 하는 업무, 기관의 개인정보시스템을 관련 법률과 기관의 정보 보호 규정에 적합하도록 관리하는 등의 업무를 수행한다.

3. 개인정보 보호 및 보안 감사
1) [부록1. 정보보안감사 지침]에 따라 감사를 실시한다.
2) 필요 시 수시 감사를 시행한다.

4. 개인정보 외부위탁관리
1) 개인정보를 취급하는 외주용역업체 직원의 경우 정보 보호 서약서를 제출한다.
2) [부록2. 외주용역 보안관리 지침]에 따라 관리한다.

5. 정보자산관리
1) [부록3. 정보자산관리 지침] 제5조 및 제7조에 따라 자산을 식별, 분류하여 중요성을 평가하고 자산 반출입을 관리한다.

6. 물리적 보안
1) 주요 인프라 시설 구역, 서버실, 통신실, DR센터 등을 제한구역 및 통제구역으로 지정하여 인가자에 한해 출입을 허용한다.
(1) 제한구역은 출입허용 여부를 식별하기 위하여 정맥인식기, 디지털 도어록, 출입증(출입카드) 등을 사용할 수 있다.
(2) 통제구역은 출입허용 여부를 식별하기 위하여 정맥인식기, 디지털 도어록, 출입증(출입카드) 등을 사용하며, 필요 시 CCTV 시스템을 통한 모니터링 및 출입기록 관리를 시행한다.

7. 시스템 개발 시 보안관리
1) 시스템 개발 및 테스트 시스템은 운영시스템과 분리하는 것을 원칙으로 한다.
2) [부록4. 개발 및 응용시스템 보안 지침]에 따라 관리한다.

8. 접근통제관리
1) 정보시스템 접근통제
(1) 방화벽, 웹방화벽, 침입방지 시스템(IPS, Intrusion Prevention System), 시스템 접근제어 통제시스템 등을 설치하여 운영한다.
(2) 백신 및 매체제어 등의 보안프로그램을 설치하여 운영한다.
2) 정보시스템 접근권한
(1) 전자 의무기록, 영상 의무기록과 전자화 된 환자 정보(처방전달시스템(OCS, Order Communication System), 의료영상저장전송시스템(PACS, Picture Archiving and Communication System), 검사결과지 등)의 접근 범위 및 권한은 직종별, 목적별,

부서별, 업무별, 서식별 등으로 분류하여 조회(열람), 입력(수정 포함), 출력, 삭제로 차등 부여한다.

(2) 의료정보시스템 사용자는 개인별 ID 와 비밀번호를 부여하며, 신원확인을 위한 공인인증서 등의 인증시스템을 추가 적용한다.

(3) 전보, 휴직, 퇴직 등 인사변동 발생 시 자동 접근통제 되며, 재할당 또는 유효일자 조정을 시행한다.

(4) 세부사항은 [12.1.3. 의무기록/의료정보 접근 권한]을 따른다.

3) 의료행위와 관련된 정보시스템 접속기록의 보관 및 위변조 방지를 위한 방안

(1) OCS/EMR(Electronic Medical Record) 접속이력을 관리하며, 기록된 접속이력 정보는 변경할 수 없다.

(2) 접속이력 기록은 사용자의 계정, IP(Internet Protocol) 주소, 접속시간/로그아웃 시간을 남겨야 하며, 쓰기, 수정, 삭제, 출력에 대한 접근기록을 관리한다.

(3) 비정상적인 접속기록(허용된 권한 외의 접속, 비정상적으로 많은 데이터 다운로드 등)에 대해서 관리한다.

(4) 접속이력은 최소 2년 이상 보관한다.

4) 규정 위반 사례 관리

(1) 정보시스템 접근 권한을 정기적으로 재검토하며 필요시 조치를 취한다.

(2) 접속현황에 대해 정기적으로 모니터링하여 비인가자에 의한 정보시스템 접속을 방지한다.

(3) 규정 위반 사례 발생 시 관련 절차에 따라 위원회를 개최하여 사례 분석 및 개선활동을 시행한다.

9. PC 및 개인용 휴대 단말기 관리

1) PC에는 백신 및 보안프로그램을 설치하여야 한다.

2) 모바일 컴퓨팅 시스템을 이용하는 경우 [부록5. 사용자 보안관리 지침] 제36조에 따라 관리한다.

10. 전산운영관리

1) 서버, 네트워크, 보안 장비 등은 주기적인 점검을 통하여 보안에 취약한 설정이 되어 있는지 확인하며, 최신 패치 상태를 유지하도록 한다.

2) 시스템 로그는 최소 6개월 이상 보관하되, 개인정보를 처리하는 경우 2년 이상 보관하여야 하며, 장애 발생 시 신속하게 복구할 수 있도록 한다.

11. 침해사고관리

1) 침해사고 발생 시, 침해사고의 유형과 위험등급을 고려하여 [부록7. 침해사고 대응 지침]에 따라 신속히 조치를 취한다.

12. 사용자 계정관리(사용자의 ID와 비밀번호 사용 원칙)

1) 비밀번호는 다음 문자 종류 중 2종류 이상을 조합하여 최소 10자리 이상 또는 3종류 이상을 조합하여 최소 8자리 이상의 길이로 구성해야 한다.

(1) 영문 대문자 – 26개

(2) 영문 소문자 – 26개
(3) 숫자 – 10개
(4) 특수문자 – 32개

2) 비밀번호는 연속적인 숫자나 생일, 전화번호 등 추측하기 쉬운 숫자의 사용을 금하며, 신규 비밀번호 설정 시 이전 4회의 비밀번호는 사용할 수 없다.
3) 비밀번호는 90일에 1회 이상 반드시 변경해야 한다.
4) 비밀번호 입력 시 5회 이상 오류가 발생한 경우, 안전한 본인 인증 수단을 통하여 비밀번호를 재설정하도록 한다.

13. 개인정보보호 교육 및 서약서 작성
1) 의무기록팀 또는 디지털헬스실은 환자 개인정보보호에 대한 교육을 정기적 또는 필요 시 수시로 시행한다.
2) 환자정보는 비밀사항으로 환자의 의무기록 및 정보를 접하는 모든 교직원은 개인정보보호에 대한 정기적인 교육을 받는다.
3) 의무기록팀을 비롯하여 의무기록 및 정보를 접하는 모든 직원과 외부 용역직원은 임용 시 업무와 관련하여 얻게 되는 환자의 개인정보에 대해 보안을 유지할 것을 서약하는 '정보보호 서약서'를 작성한다.

제4조 (부록)
1. 정보보안감사 지침
2. 외주용역 보안관리 지침
3. 정보자산관리 지침
4. 개발 및 응용시스템 보안 지침
5. 사용자 보안관리 지침
6. 개인정보보호 관리 지침
7. 침해사고 대응 지침

제5조 (참고)
1. 개인정보보호법
2. 개인정보의 안전성 확보조치 기준
3. 연세의료원 정보보호 규정 및 지침서

내규의 제·개정 이력

제1조 (내규의 제정 및 시행)
1. 이 내규는 2014년 10월부터 시행한다.

제2조 (내규의 전면개정 및 시행)
1. 이 내규는 2025년 3월 25일부터 시행한다.

제3조 (내규의 개정)

승 인: 세브란스병원장 이 강 영 (인)